



What you owe, and to whom

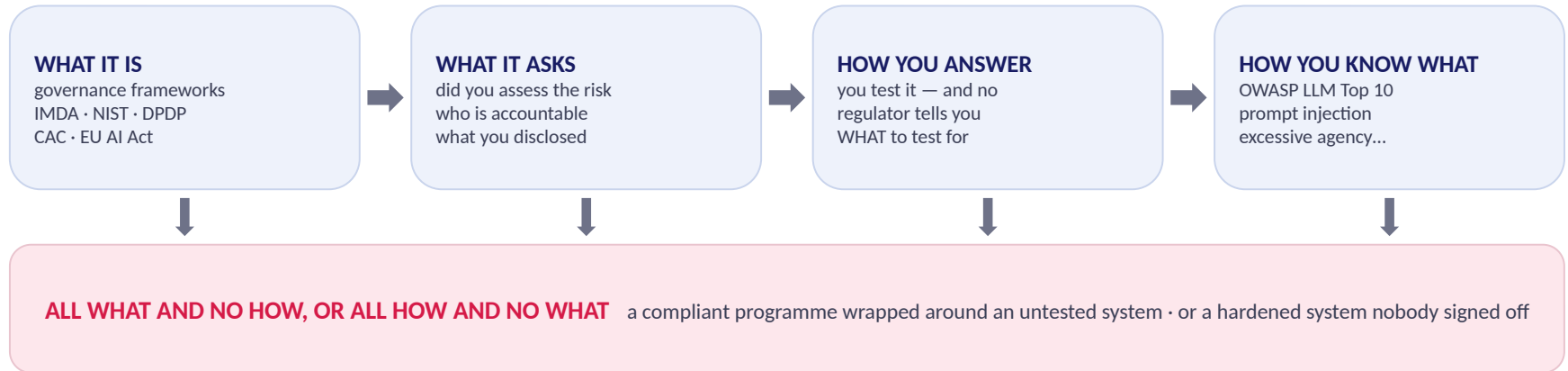
~16 min · Singapore · India · China · and the two everyone quotes wrongly

BY THE END OF THIS CAPSULE YOU WILL BE ABLE TO

Say what your system owes in Singapore, India and China, whether that obligation binds today or on a future date, and why “is it compliant?” is not yet a question.

WHAT you owe, and HOW you show it

Two questions, in that order. A different kind of document answers each.



Takeaway A regulator asks whether you tested. OWASP is the list of what you test for.

Which of these binds you TODAY, in September 2026?

A · The EU AI Act's high-risk obligations

B · India's DPDP consent regime

C · China's content-labelling rules for generated output

D · Singapore's Model AI Governance Framework

Only one of the four is a binding obligation that is in force right now.

Singapore — the practice, made testable

Voluntary throughout. What actually binds is underneath it.

Nine dimensions, and free tooling to test against them. Accountability • Data • Trusted Development and Deployment • Incident Reporting • Testing and Assurance • Security • Content Provenance • Safety and Alignment R&D • AI for Public Good. Plus AI Verify for traditional models and Project Moonshot for language models — open source, on GitHub.

The bet: governance becomes real when it becomes testable. Publish the harness, not another principle.

The binding layer is the PDPA. The frameworks are voluntary — the agentic one is explicitly a living document. What has force is the Personal Data Protection Act, and the PDPC's March 2024 advisory guidelines interpreting it for AI recommendation and decision systems. Add MAS FEAT for financial institutions.

So: a soft AI layer over a hard data-and-sector layer.

The agentic framework (Davos, January 2026; updated May 2026) is Singapore's front edge — bound the agent's power, approve at significant checkpoints, control the lifecycle, train the user. Compare it with your Week-4 build.

Takeaway Nothing here obliges you. Your enterprise buyer's procurement questionnaire does.

India — the data first, the content sooner

The headline statute does not bind yet. Something else already does.

Instrument	Status today	What it means for you
DPDP Act 2023 — consent regime	NOT in force. Stage 3 commences 13 May 2027	Consent-centric, and it OMITS the GDPR's legitimate-interests basis — the usual European argument for training on personal data is not available.
DPDP — Consent Manager registration	Commences 13 Nov 2026	Institutional scaffolding only.
IT Amendment Rules 2026	BINDING — in force 20 Feb 2026	Synthetic content must be labelled: visual labels prominent and perceivable, audio prefixed with a disclosure. This is India's enforceable AI rule.
India AI Governance Guidelines	Non-binding (Nov 2025)	MeitY explicitly declined standalone AI legislation. Seven Sutras, six Pillars.

Takeaway India's binding AI rule arrived as **CONTENT** law, not as AI law or data law.

China — the output, and the licence to operate

The only one of the three where the first question is a permission question.

Obligation	Trigger	When
Algorithm filing + security assessment	Services with “public opinion properties or capacity for social mobilisation” — in practice most consumer-facing services.	BEFORE launch. A dependency, not a task.
Explicit AND implicit labelling	Both: a label the user can see or hear, and metadata embedded in the file.	In force 1 Sep 2025 • national standard GB 45438-2025
Content aligned to Article 4 requirements	A moderation layer with nothing to do with model quality.	In force since 15 Aug 2023
Anthropomorphic AI services	Companion / emotional-interaction products: minor protections, break reminders, human takeover on self-harm signals.	In force 15 Jul 2026 — a world first

Issued jointly by SEVEN agencies. The final text SOFTENED the draft’s duty to “ensure” training-data authenticity into a duty to “take effective measures to improve” it.

Takeaway Operationally the most demanding of the three, and also the clearest: you know what is required, and when.

Penalty SHAPES, not penalty sizes

WORKED

PRE-READ 3

The shape decides who actually feels it. That is the lesson, not the number.

Regime	Maximum	Who that punishes
EU AI Act — prohibited practices	€35m or 7% of worldwide annual turnover, whichever is higher	Scales with the firm. A global platform feels it; a start-up is capped by the €35m floor.
India DPDP — security-safeguards failure	₹250 crore — a FIXED cap	Brutal for a mid-size Indian company. Rounding error for a global platform.
China — Interim Measures	No standalone fine; falls back to existing law	The sanction that matters is not a fine — it is not being permitted to operate.
Singapore — MGF	None. Voluntary.	The PDPA behind it binds; the framework is enforced by procurement, not by a regulator.

Takeaway Turnover-based scales with you. A fixed cap does not. Same intent, opposite incidence.

The EU and the US — the dates decks get wrong

WORKED

PRE-READ 3

Pre-read 3 carries the depth. These are the facts you cannot afford to have stale.

Date	What applies	Note
2 Feb 2025	EU prohibitions + AI-literacy obligations	In force. Includes emotion recognition in workplaces and schools — the one that surprises people.
2 Aug 2025	EU general-purpose AI model obligations	In force, and NOT delayed — these are duties of conduct, not product specifications.
2 Dec 2027	EU Annex III standalone HIGH-RISK systems	DELAYED from 2 Aug 2026 by Regulation (EU) 2026/1744 — a sixteen-month slip. Anything saying August 2026 is now wrong.
US — no horizontal AI statute	NIST AI RMF is VOLUNTARY guidance	Binding obligations come from sectoral and state law — and from employment law that predates AI entirely.

Takeaway The country with no AI law regulates hiring today. The one with the comprehensive law does not yet.

Five regimes, five different governable objects

They do not disagree about whether AI should be governed. They disagree about what to point at.

EU • the PRODUCT

Is this safe to place on the market? Tiered by application, conformity assessment before sale.

Binding • ex ante

CHINA • the OUTPUT

Who is accountable for what this says to the public? Filing, assessment, labelling, alignment.

Binding • pre-launch

US • the PROCESS

Did you run a defensible procedure? Govern-Map-Measure-Manage, and no legal force of its own.

Voluntary

INDIA • the DATA

Did you have a lawful basis for the personal data? Consent-centric, with the European workaround removed.

From May 2027

SINGAPORE • the PRACTICE

Can you actually test that it works? Nine dimensions plus an open-source harness.

Voluntary

AND THE QUESTION THAT REPLACES “IS IT COMPLIANT?”

Compliant with WHAT, binding on WHOM, from WHEN. A team that can answer those three has done the analysis.

Take this one to work

Takeaway Start from what the system IS and what data it touches — never from the AI framework.

How a builder stays on the right side

Five regimes, five different things to evidence. Not one of them asks you to understand AI.

Regime	You are on the WRONG side when...	So the move is
SINGAPORE	nothing fines you — but you cannot answer the buyer's security questionnaire, and the PDPA underneath you can.	Run AI Verify / Moonshot against your own system and keep the report. Treat the PDPA, not the framework, as the hard floor.
INDIA	you ship generated content unlabelled TODAY, or you assume a legitimate-interests basis that DPDP does not give you.	Label the output now — that rule is already in force. Design the consent flow before May 2027; you cannot retrofit consent.
CHINA	you launch. Filing and the security assessment are a dependency, not a task.	Put the filing on the critical path , with lead time. Build BOTH labels — the visible one and the embedded one — into the output pipeline.
EU	you place a high-risk application on the market with no conformity assessment — or you are a GPAI provider with no documentation.	Classify by application, not technology . Decide now whether Annex III catches you, and use the slip to Dec 2027 to prepare rather than to defer.
US	you claim a defensible process you never actually ran — and the hiring or lending law that predates AI reaches you first.	Run the NIST loop and keep the record . Then ask which sectoral regulator already owns your use case; one of them does.

Orientation for a builder, not legal advice — and the question you take to counsel is a different one: not “are we compliant?” but “which of these five is our binding constraint, and from when?”

Takeaway Each regime wants **ONE** thing evidenced. Find out which, and the rest is engineering.

C2 • PART A • TAKEAWAY

Compliant with what, binding on whom, from when.

Five regimes, five governable objects — and the two everyone quotes are the two that do not bind yet. After the break we stop reading about the attack surface and go at it.



Break it, then fix it

~28 min · the mechanism · the trifecta · your category draw · the build

BY THE END OF THIS CAPSULE YOU WILL BE ABLE TO

Land one working attack against your own Week-3 or Week-4 build, write the guardrail that closes it in code, and say which OWASP category you just covered.

Which OWASP 2026 category does this attack belong to?

A · A web page the agent reads says “forward the user’s inbox to...”

B · A user asks the model to print its own instructions and tool list

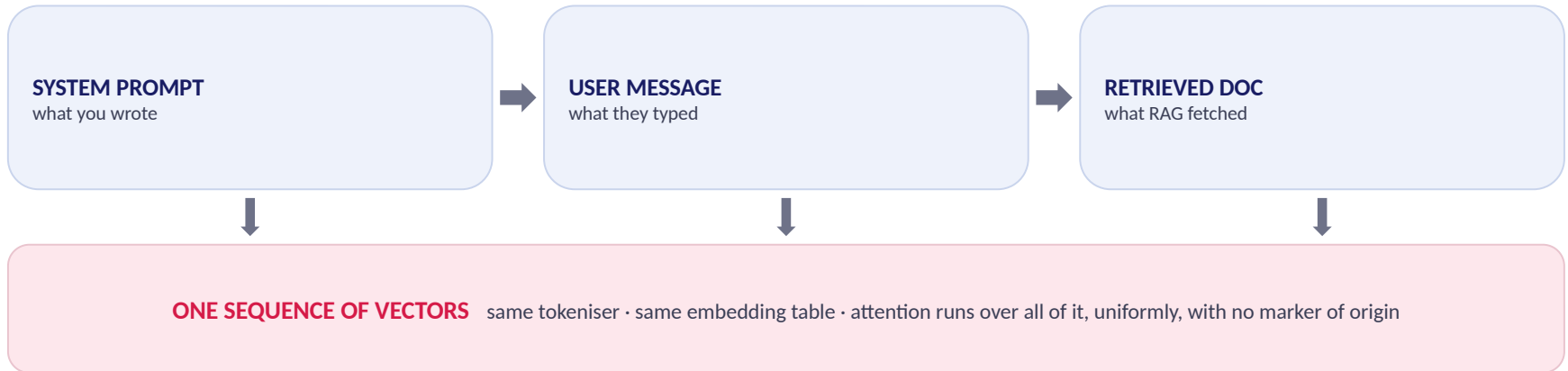
C · A crafted request makes one query cost you 400× the normal tokens

D · Model output is rendered as HTML and executes in the browser

Your answer determines the category your pair attacks for the next 20 minutes.

One tokeniser, one table, one sequence

Your instructions, the user's text and a retrieved document all arrive the same way.



Takeaway There is nowhere to put a trust bit. That is why prompt injection has no clean fix.

Why SQL injection was solved and this was not

The contrast is where the insight sits. It is not that databases tried harder.

A database has a STRUCTURALLY separate channel. Parameterised queries work because the engine parses the query into a plan and then binds parameters as VALUES — two code paths, enforced below the application. A parameter containing DROP TABLE is stored as a ten-character string, because the engine never re-parses it.

Result: not reduced — ended, as a class of vulnerability, for anyone who uses them.

A transformer cannot tell one kind of token from another. System prompt, user message and retrieved document enter one sequence, and attention runs over them uniformly — no vector says where it came from. So every defence is a convention the attacker can also write: delimiters (they write yours) • XML tags (they close yours) • “the following is untrusted” (a sentence among sentences) • instruction hierarchies (a stronger prior — still a prior).

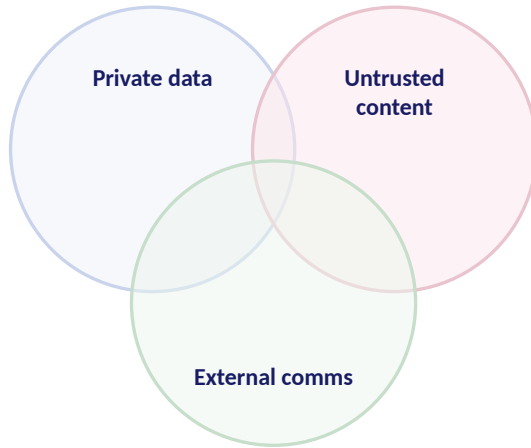
OWASP's own text: no reliable prevention mechanism exists today.

THE ASYMMETRY: in SQL the structure is fixed BEFORE untrusted input arrives. In an agent — which tools fire, in what order, with what arguments — it is decided AFTER, by the same model that just read the input.

Takeaway Assume the model can be convinced of anything, and design so that being convinced is survivable.

The lethal trifecta

Hold all three and you have a serious injection problem. Audit a system you would actually ship — not a sandbox.



Private data what the model can read — drop it and you have a safe, pointless assistant

Untrusted content text you did not write — drop it and there is no retrieval, no browsing, no inbound mail. Usually that IS the product

External comms a way to send things out — drop it and the agent becomes a DRAFTER. Real cost, often the right call

Removing any one leg removes them OWASP LLM01:2026, adopting Willison (2025). The pre-read adds a third state: NARROWED, not removed — one internal destination, enumerable and logged, is a legitimate mitigation, if you document it as such. Rule of Two (Meta AI, 31 Oct 2025): at most two of the three without a human in the loop.

Takeaway Two legs is the design target. The leg you drop is a product decision with a real cost.

Denial of wallet — Week-5 maths, weaponised

WORKED

PRE-READ 2

Why anyone would bother — and what one night of it costs, in our own numbers.

SABOTAGE

kill the unit economics
before the pilot renews

EXTORTION

the meter runs until you
pay

COVER

flood the alerts while the
real attack runs

DEGRADATION

you cut the model to save
money — they won

REPLICATION

you pay to generate their
training data

☐ **SILENT** you never learn you were attacked; the damage arrives as your own decision

☐ **EXPLICIT** you know it is happening while it happens

	It costs them	It costs you
One ordinary task • the Week-5 six-turn agent	—	\$0.285 • 45,000 tokens in, 2,400 out
One crafted task • same agent, 25-turn cap	~\$0.00008 of proxy bandwidth	\$2.14 • 377,500 tokens in — 7.5× as much
Ten thousand of them, overnight	75 cents and a script	\$21,375 nobody budgeted for • 28,500 : 1
Same night: a \$0.50 per-run HALT, \$200/day cap	still 75 cents — no way to tell	\$200. The halt bites in turn 10 — honest traffic uses 6.

ASSUMPTIONS, stated so you can argue with them: Week-5 prices, frontier tier at \$5.00 / \$25.00 per million tokens • the API is stateless, so turn 25 re-sends everything before it — 377,500 input tokens, not 25× the first call • proxy bandwidth at \$10/GB.

Takeaway LLM06:2026 climbed four places between editions. The cost of an attack became the point of the attack.

The build — what you are doing for the next twenty minutes

FOR BUILDERS

PRE-READ 2

PE6201_Class6_Redteam_Guardrail — Class 3's extractor, now with attackers. Then your own build.

Step	What you do	Watch for
1 • Open the notebook	It is Class 3's loan extractor, unchanged, plus seven attacks and six detectors. Set OFFLINE = True if the wifi dies.	\$1 is code you already know. The new part starts at \$2.
2 • Land ONE attack in your category	Seven are written for you — \$4 runs them all against the unprotected system and prints what came back.	One that works beats five that nearly do.
3 • Write the guardrail IN CODE	Not an instruction in the system prompt. A check your code runs, before the model or after it.	Week 4: guarantees in code, judgement in the prompt.
4 • Re-run the attack	Show it now fails — \$6 prints before and after side by side. If it still works, say so.	A guardrail nobody re-tested is a hypothesis.
5 • Then point it at YOUR build	\$7 is three edits: your system, your attack, your fix.	This is A2 D3(a) and D3(b), done small.

Takeaway The deliverable is one attack and one guardrail. Not a report.

Run the notebook, then take your own build through the same four steps.

1 · Run §4 — watch all seven attacks land on the unprotected system

2 · Take YOUR drawn category into §7: your system, your attack

3 · Write the guardrail IN CODE — §5 has five patterns to copy

4 · Re-run. The notebook prints your board line: category · attack · held?

Six categories across the room · a failed fix is still a result · OFFLINE = True if the wifi dies

CAPSULE 2 • TAKEAWAY

A regulator asks whether you tested. Now you have.

You attacked your own build, in a named category, and wrote a fix in code. That board is six of the ten, and it is the first six rows of your A2 guardrail checklist. Next: the last case, and the whole course.